

Governance, Risk, and Compliance (GRC)

Aananth S

<https://www.linkedin.com/in/aananth-s-0a3392164/>

Steering Committee

A steering committee serves as an effective communication channel for management's aims and directions and provides an ongoing basis for ensuring alignment of the security programme with organizational objectives. It is also instrumental in achieving behaviour change toward a culture that promotes good security practices and policy compliance.

Value Management

Value Management in Governance, Risk & Compliance ensures organizational objectives are achieved by aligning resources and processes with strategic goals. It identifies and maximizes value opportunities, mitigates risks, ensures adherence to regulations, and fosters transparent governance, enhancing overall efficiency, resilience, and sustainable growth within the enterprise framework.

Quality Management

- λ Software development, maintenance and implementation
- λ Acquisition of hardware and software
- λ Day-to-day operations
- λ Service management
- λ Security
- λ Human resource management
- λ General administration

Security

Security is the result of a process. The better the security process, the better the protection achieved from the resources available. Using Security in Context, an incident is defined as a failure to meet the organization's Security Objectives. Since the definition is context dependent, ISM3 does not consider any single set of security measures or security management processes as compulsory or useful for all organizations.

Expand COSO

Committee of Sponsoring Organizations of the Tread-way Commission developed a model for evaluating internal controls. This model has been adopted as the generally accepted framework for internal control and is widely recognized as the definitive standard against which organizations measure the effectiveness of their systems of internal control.

Risk Response

This is the process of selecting and implementing measures to manage the risk. The challenge for risk managers is to determine a portfolio of appropriate responses that form a coherent and integrated strategy such that the net remaining risk falls within the acceptable level of exposure. It is important to note that there is no right response to risk. The choice of response will depend on issues such as the organization's risk appetite, the impact and probability of the risk and the costs and benefits of the mitigation plans.

Responses to risk generally fall into the following categories: Risk avoidance, Risk reduction, Risk acceptance.

Compliance

Compliance in Governance, Risk & Compliance (GRC) ensures organizations adhere to laws, regulations, industry standards, and internal policies. It mitigates legal and financial risks by enforcing rules, monitoring processes, and implementing corrective actions. Effective compliance strengthens governance, fosters accountability, and protects the organization's reputation while ensuring ethical conduct.

BASEL

BASEL COMMITTEE ON BANKING SUPERVISION is a committee of banking supervisory authorities that was established by the central bank governors of the Group of Ten (G10) countries in 1974. The committee expanded its membership in 2009 and then again in 2014. As of 2019, the BCBS has 45 members from 28 jurisdictions, consisting of central banks and authorities with responsibility of banking regulation.

Scope of Governance

The scope of Governance in Governance, Risk & Compliance (GRC) involves establishing frameworks, policies, and processes to guide organizational decision-making and accountability. It includes defining roles, responsibilities, and structures that ensure transparency, ethical behaviour, and alignment with strategic objectives. Governance oversees risk management, compliance adherence, and overall performance, fostering long-term sustainability and stakeholder trust.

Strategic planning

Information System Strategic Planning has been prescribed by King (1978) as a process that serves to relate the organization's mission, objectives, and strategies, and other salient characteristics to an Information System strategy set." The Information System strategy set is the product of the strategic planning process for "IS" in that it is derived from the organization's "strategy set" through the application of strategic planning methods to the IS function.

Financial management

Financial management in a business seeks to plan and direct the use of the company's financial resources, cashes it generates through its operations and the capital obtained from investors or lenders. Although a company may have an accounting staff or an outside accounting firm to provide financial guidance, financial management is one of the most important aspects of the business owner's job.

Expand NIST

The Risk Management Framework (RMF) is a set of criteria that dictate how the United States government IT systems must be architected, secured, and monitored. Today, the RMF is maintained by the National Institute of Standards and Technology (NIST) and provides a solid foundation for any data security strategy. NIST is responsible for developing information security standards and guidelines, including minimum requirements for federal information systems.

Internal control activities

Internal control activities within Governance, Risk & Compliance (GRC) are the procedures and mechanisms designed to ensure that organizational objectives are met efficiently, risks are managed, and compliance with laws and policies is maintained. These activities include segregation of duties, authorizations, reconciliations, performance reviews, information security, and documentation controls, all aimed at preventing errors, fraud, and ensuring accurate reporting and regulatory adherence.

Objectives of governance

The objectives of governance in Governance, Risk & Compliance (GRC) are to ensure effective decision-making, accountability, and transparency within an organization. It aims to align organizational actions with strategic goals, safeguard stakeholders' interests, maintain ethical standards, and promote sustainable growth. Governance also ensures that risks are managed appropriately and that compliance with legal and regulatory requirements is maintained.

Need for IT Governance

IT governance is an element of corporate governance, aimed at improving the overall management of IT, and driving improved value from its investment in information and technology. IT Governance framework enables organizations to effectively manage its IT risks and ensures that the activities associated with information and technology are aligned with the overall business objectives. ISO 38500 is the international standard for IT governance

λ Assure stakeholders that they can have confidence in the organization's IT services. λ Facilitate an increase in the return on IT investment. λ Comply with certain corporate governance or public listing rules or requirements

Expand ITIL

ITIL or IT Infrastructure Library®, was developed by the UK's Cabinet Office as a library of best-practice processes for IT service management. Widely adopted around the world, ITIL is supported by ISO/IEC 20000:2011, against which independent certification can be achieved. On ITIL page, can access a free briefing paper on ITIL, IT service management and ISO 20000

ISO

International Organization for Standardization is an independent, non-governmental, international standard development organization composed of representatives from the national standards organizations of member countries

Risk Management

Risk management does require some investment of time and money, but it does not need to be substantial to be effective. In fact, it will be more likely to be employed and maintained if it is implemented gradually over time.

Quality approach in compliance

A quality approach in compliance within Governance, Risk & Compliance (GRC) focuses on continuous improvement, consistency, and adherence to high standards. It involves implementing robust compliance frameworks that ensure conformity with regulations, industry standards, and internal policies. This approach emphasizes proactive monitoring, regular audits, employee training, and corrective actions to prevent non-compliance, mitigate risks, and enhance organizational accountability, ensuring both legal and operational excellence.

Information security

Information security in Governance, Risk & Compliance (GRC) involves protecting an organization's data and systems from unauthorized access, breaches, and cyber threats. It encompasses policies, controls, and technologies to ensure the confidentiality, integrity, and availability of information. Governance sets the framework for security protocols, risk management identifies vulnerabilities, and compliance ensures adherence to legal regulations like GDPR or HIPAA, safeguarding sensitive data and minimizing cyber risks.

Quantified Risk

Quantified risk in Governance, Risk & Compliance (GRC) refers to the process of assigning numerical values to risks based on their likelihood and potential impact. This approach allows organizations to prioritize risks, allocate resources effectively, and make data-driven decisions. Quantifying risks helps in measuring financial exposure, determining risk tolerance, and aligning risk management strategies with governance objectives, ensuring a balanced approach to mitigating threats and maintaining compliance.

Audit – Manual

An audit manual usually contains an overview of the industry risk factors facing an organization as well as the protocol of the audit process, the tools and methodologies for conducting the audit, forms to be completed, and people to contact. As such, it facilitates orientation and saves time on training newly appointed staff on the audit activity - auditors can begin audit engagements immediately

Audit Check List

Audit checklist is a key element in planning for and carrying out a process audit. The checklist for any internal quality audit is composed of a set of questions derived from the quality management system standard requirements and any process documentation prepared by the company.

Risk Mitigation

Risk mitigation planning is the process of developing options and actions to enhance opportunities and reduce threats to project objectives. Risk mitigation implementation is the process of executing risk mitigation actions. Risk mitigation progress monitoring includes tracking identified risks, identifying new risks, and evaluating risk process effectiveness throughout the project.

Risk

Risk refers to the possibility of an event or condition that can negatively impact objectives or outcomes. It involves uncertainty and the potential for loss or harm, affecting areas such as finances, operations, or reputation. Effective risk management identifies, assesses, and mitigates risks to minimize their impact on an organization or individual.

Expand OECD

Organization for Economic Co- Operation and Development is an intergovernmental organisation with 38 member countries, founded in 1961 to stimulate economic progress and world trade. It is a forum whose member countries describe themselves as committed to democracy and the market economy, providing a platform to compare policy experiences, seek answers to common problems, identify good practices, and coordinate domestic and international policies of its members.

Information

Information is data that has been processed, organized, or structured to provide meaning and context. It enables decision-making, communication, and understanding by conveying knowledge, facts, or insights. Information can be shared, stored, and retrieved, playing a crucial role in education, business, and everyday life for informed choices and actions.

Mitigate risk

To manage and mitigate risks and reduce potential impacts on information assets to an acceptable level. λ Account for and protect all IT assets. λ Establish and reduce the likelihood and impact of IT security risks. λ Perform regular risk assessments with senior managers and key staff. λ Permit access to critical and sensitive data only to authorized users.

Risk in Governance

Governance, Risk, and Compliance (GRC) refers to the integrated approach organizations take to align governance practices, manage risks, and comply with regulations. It ensures that companies meet legal requirements, mitigate potential risks, and maintain ethical standards. GRC enhances decision-making, reduces financial risks, and fosters a culture of accountability across the organization.

Information at risk

Information at risk in Governance, Risk, and Compliance (GRC) refers to the potential threats to the security, integrity, and confidentiality of data within an organization. Weak governance, poor risk management, and regulatory non-compliance can lead to breaches, data loss, or misuse, impacting business operations, reputation, and legal standing.

Why should performance be measured?

In Governance, Risk, and Compliance (GRC), measuring performance is essential to ensure that governance policies, risk management strategies, and compliance efforts are effective. It helps identify gaps, track progress, and ensure alignment with organizational goals. Regular measurement enables continuous improvement, accountability, and mitigates risks by addressing issues proactively.

How is Bench Mark Set?

In Governance, Risk, and Compliance (GRC), benchmarks are set by analyzing industry standards, regulatory requirements, and best practices. Organizations assess internal performance, compare it with peers or established standards, and define key metrics for governance, risk, and compliance objectives. Benchmarks guide performance evaluation, ensuring alignment with legal and industry expectations.

Sarbanes Oxley Act of USA

The Sarbanes–Oxley Act of 2002, also known as the “Public Company Accounting Reform and Investor Protection Act” and “Corporate and Auditing Accountability, Responsibility, and Transparency Act” (in the House) and more commonly called Sarbanes–Oxley or SOX, is a United States federal law that set new or expanded requirements for all U.S. public company boards, management and public accounting firms.

Expand ISACA and write a note

Information Systems Audit and Control Association COBIT (Control Objectives for Information and Related Technologies) is a framework created by ISACA for information technology (IT) management and IT governance. The framework defines a set of generic processes for the management of IT, with each process defined together with process inputs and outputs, key process-activities, process objectives, performance measures and an elementary maturity model.

Need for strategic alignment

It is often difficult to achieve the goal of strategic alignment of information security in support of organizational objectives.

- λ Ensure transparency and understanding of IT security costs, benefits, strategy, policies and service levels.
- λ Develop a common and comprehensive set of IT security policies.
- λ Communicate the IT strategy, policies and control framework
- λ Enforce IT security policies.
- λ Define security incidents in business impact terms.
- λ Establish clarity on the business impact of risks to IT objectives and resources.
- λ Establish IT continuity plan that supports business continuity plans.

Personnel Management

Personnel management can also be defined as, that field of management which is concerned with the planning, organizing, directing and controlling various operative functions of procurement, development, maintenance and utilization of a labor force in such a way that objectives of company, those of personnel at all levels and those of community are achieved.

- λ Encourage the technical development of all team members
- λ Train technical and non-technical personnel on compliance requirements
- λ Assorted other managerial tasks and responsibilities

Risk Management process

The four main risk categories of risk are hazard risks, such as fires or injuries; operational risks, including turnover and supplier failure; financial risks, such as economic recession; and strategic risks, which include new competitors and brand reputation. Being able to identify what types of risk you have is vital to the risk management process.

IS Policies

The program should be grounded in a clear, board-level information security policy that positions it as a business issue, mandates the need for a comprehensive program, delegates authority to the role of an information security officer and establishes clear reporting requirements back to the board of directors.

Compliance Officer

A Compliance officer is responsible for ensuring a company's policies and procedures comply with regulatory and ethical standards. Also referred to as a Compliance Specialist, these highly analytical professionals perform regular audits, implement company policies, and design control systems.

Audit Reports

Audit reports are formal evaluations of an organization's financial records, internal controls, or compliance with laws and regulations. In Governance, Risk, and Compliance (GRC), audit reports assess the effectiveness of risk management, governance structures, and adherence to legal standards. They provide insights into potential gaps, recommend improvements, and enhance transparency and accountability in decision-making. Audit reports are critical for stakeholders, helping ensure that an organization operates efficiently, ethically, and within the bounds of its regulatory obligations.